

**LAPORAN PRAKTIKUM KEAMANAN INFORMASI DASAR
IMPLEMENTASI AUTHENTICATION DAN ROLE-BASED ACCESS
CONTROL (RBAC) - CLEAN**

Dosen Pengampu : Syahru Rahmayuda, S.Kom., M.Kom



Disusun Oleh

Ghina Audhiya Khairunisa - H1101241015

**PROGRAM STUDI SISTEM INFORMASI
FAKULTAS MATEMATIKA DAN ILMU PENGETAHUAN ALAM
UNIVERSITAS TANJUNGPURA PONTIANAK**

2026

1. PENDAHULUAN

Pada praktikum ini dilakukan implementasi sistem authentication dan authorization berbasis Role-Based Access Control (RBAC) pada sebuah REST API menggunakan Bun, Express, Prisma, dan MySQL. Sistem authentication digunakan untuk memverifikasi identitas pengguna melalui email dan password, sedangkan authorization digunakan untuk mengatur hak akses pengguna berdasarkan role tertentu. Dalam implementasi ini digunakan JSON Web Token (JWT) sebagai mekanisme autentikasi. Setelah pengguna berhasil login, sistem akan menghasilkan token JWT yang digunakan untuk mengakses endpoint yang memerlukan autentikasi. Selain itu, diterapkan pembatasan akses berdasarkan role USER dan ADMIN sehingga hanya pengguna tertentu yang dapat mengakses endpoint khusus administrator. Tujuan utama praktikum ini adalah.

1. Memahami konsep authentication pada REST API
2. Memahami konsep authorization berbasis Role-Based Access Control (RBAC)
3. Mengimplementasikan fitur register dan login menggunakan JWT
4. Menguji pembatasan akses endpoint berdasarkan role USER dan ADMIN
5. Mendokumentasikan proses implementasi authentication dan authorization pada API

2. LINGKUNGAN PRAKTIKUM

Tabel 1. Lingkungan Praktikum

Komponen	Keterangan
Runtime	Bun
Framework Backend	Express.js
ORM	Prisma
Database	MySQL
API Testing	Postman
Code Editor	Visual Studio Code
Package Manager	Bun
Bahasa Pemrograman	TypeScript
Sistem Operasi	Windows 10/11

3. DASAR TEORI

Authentication adalah proses untuk memverifikasi identitas pengguna sebelum pengguna diberikan akses ke sistem. Proses ini biasanya dilakukan menggunakan email dan password. Pada praktikum ini, password pengguna disimpan dalam bentuk hash menggunakan bcrypt agar keamanan data lebih terjaga. Setelah pengguna berhasil login, sistem akan menghasilkan token JWT (JSON Web Token). Token ini digunakan sebagai identitas pengguna pada setiap request berikutnya tanpa perlu melakukan login ulang. Authorization adalah proses penentuan hak akses pengguna setelah identitasnya berhasil diverifikasi. Pada praktikum ini digunakan metode Role-Based Access Control (RBAC), yaitu pengaturan akses berdasarkan role pengguna. Role yang digunakan terdiri dari ADMIN dan USER. Role ADMIN memiliki akses penuh terhadap endpoint tertentu, sedangkan role USER hanya dapat mengakses endpoint umum sesuai izin yang dimiliki.

4. LANGKAH PRAKTIKUM

Langkah pertama yang dilakukan adalah melakukan clone repository project API RBAC yang telah disediakan. Setelah project berhasil didapatkan, dilakukan instalasi dependency menggunakan perintah Bun. Selanjutnya dilakukan konfigurasi file .env untuk menghubungkan aplikasi dengan database MySQL lokal. Setelah konfigurasi selesai, dijalankan proses migrasi database menggunakan Prisma agar seluruh tabel dapat dibuat secara otomatis. Tahap berikutnya adalah menjalankan proses seed untuk membuat data awal role dan permission. Setelah database siap digunakan, server dijalankan menggunakan Bun. Setelah server berhasil berjalan, dilakukan pengujian endpoint menggunakan Postman, meliputi

1. POST /api/auth/register
2. POST /api/auth/login
3. GET /api/test
4. GET /api/admin

Pengujian dilakukan menggunakan akun dengan role USER dan ADMIN untuk memastikan sistem authorization berjalan dengan baik.

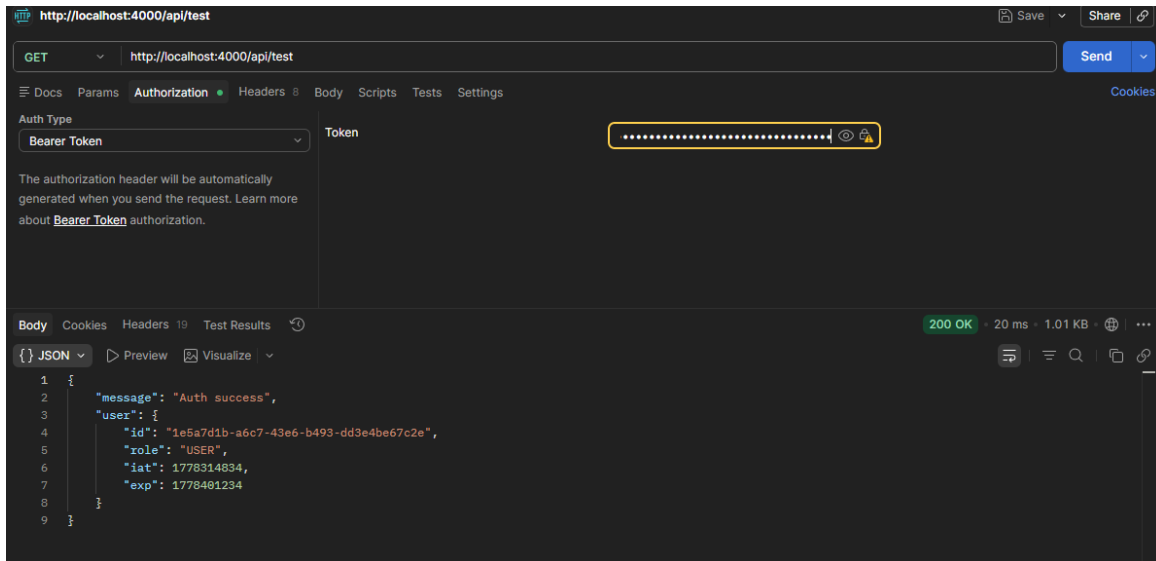
5. HASIL DAN PEMBAHASAN

5.1 Register User

Pengujian pertama dilakukan pada endpoint register untuk membuat akun baru dengan endpoint POST <http://localhost:4000/api/auth/register>.

5.3 Pengujian Authentication Token

Tahap berikutnya adalah menguji token JWT menggunakan endpoint `/api/test`. Endpoint ini digunakan untuk memastikan middleware authentication dapat membaca token dan mengenali identitas pengguna menggunakan endpoint GET <http://localhost:4000/api/test> dan holder yang digunakan adalah `Authorization: Bearer <token>`.

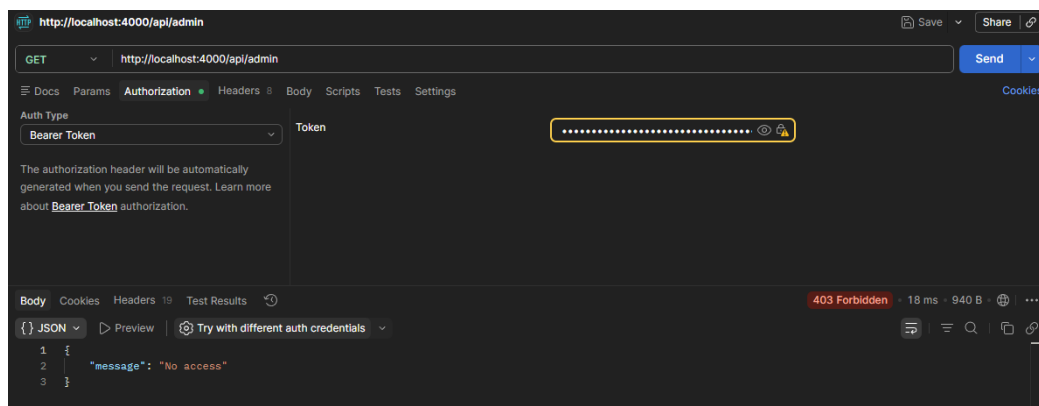


Gambar 3. Pengujian Authentication Token

Hasil pengujian menunjukkan bahwa request berhasil diproses dan sistem menampilkan informasi user berdasarkan token JWT yang diberikan. Output juga menunjukkan bahwa role pengguna adalah `USER`.

5.4 Pengujian Endpoint Admin Menggunakan Role USER

Pengujian berikutnya dilakukan menggunakan akun dengan role `USER` untuk mengakses endpoint admin GET <http://localhost:4000/api/admin>.

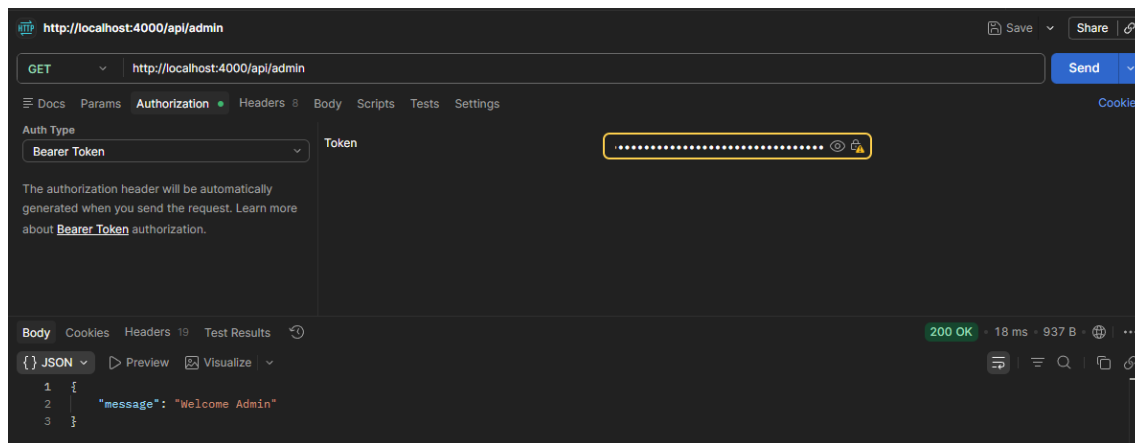


Gambar 4. Pengujian Endpoint Admin Menggunakan Role USER

Hal ini menunjukkan bahwa middleware RBAC berhasil melakukan pembatasan akses berdasarkan role pengguna.

5.5 Pengujian Endpoint Admin Menggunakan Role ADMIN

Tahap terakhir dilakukan dengan menggunakan akun yang memiliki role ADMIN. Setelah login berhasil, token JWT digunakan untuk mengakses endpoint admin. Hasil pengujian menunjukkan bahwa request berhasil diproses dan sistem memberikan akses penuh kepada pengguna dengan role ADMIN.



Gambar 5. Pengujian Endpoint Admin Menggunakan Role ADMIN

Keberhasilan ini membuktikan bahwa sistem authorization berbasis RBAC berhasil diterapkan dengan baik.

6. ANALISIS HASIL IMPLEMENTASI

Berdasarkan hasil pengujian yang telah dilakukan, sistem authentication dan authorization berhasil berjalan sesuai tujuan praktikum. Proses register berhasil menyimpan data pengguna baru ke database dengan password yang telah di-hash menggunakan bcrypt. Hal ini penting untuk menjaga keamanan data pengguna agar password tidak tersimpan dalam bentuk plain text. Pada proses login, sistem berhasil menghasilkan token JWT yang digunakan sebagai identitas pengguna saat mengakses endpoint tertentu. Middleware authentication mampu membaca token dan memverifikasi pengguna dengan baik. Selain itu, middleware Role-Based Access Control (RBAC) juga berhasil membatasi akses berdasarkan role pengguna. Pengguna dengan role USER tidak dapat mengakses endpoint khusus admin, sedangkan pengguna dengan role ADMIN dapat mengakses endpoint tersebut tanpa kendala.

7. KESIMPULAN

Berdasarkan praktikum yang telah dilakukan, dapat disimpulkan bahwa implementasi authentication dan authorization menggunakan Bun, Express, Prisma, dan MySQL berhasil dijalankan dengan baik. Fitur register dan login berhasil diimplementasikan menggunakan JWT sebagai mekanisme authentication. Sistem juga berhasil membatasi akses endpoint berdasarkan role USER dan ADMIN menggunakan metode Role-Based Access Control (RBAC). Hasil pengujian menunjukkan bahwa middleware authentication dan authorization bekerja sesuai dengan tujuan praktikum, sehingga keamanan API menjadi lebih terstruktur dan terkontrol. Implementasi ini menunjukkan bahwa penggunaan JWT dan RBAC dapat meningkatkan keamanan API dengan cara memisahkan hak akses pengguna sesuai role masing-masing.